

ERP.1: Авторизація

Технічні вимоги

до системи керування цифровими
ідентичностями, сертифікатами та політиками
безпеки

Зміст

Зміст

Анотація

ERP.1: Служба ідентифікації та авторизації (IAS) є центральним керуючим компонентом безпеки Zencrypted-середовища на базі Erlang/OTP. Поточна реалізація веде стійкий реєстр доменних об'єктів у KVS/Mnesia, підтримує граф зв'язків користувач–пристрій–сертифікат–профіль безпеки–VPN-сервіс, перевірку CSR і X.509, покрокове налаштування пристрою, доставку бажаного стану до VPN через Erlang RPC, ревізії, аудит доставки, звіряння стану та відновлення після збоїв. Інтеграція з CA у поточній версії містить перехідний CMP-шлях через зовнішній командний інтерфейс OpenSSL; цільовою є повне усунення запуску OpenSSL із середовища виконання IAS та взаємодія з CA через керований клієнт або сервісний адаптер. Вимоги щодо BPE/BPMN, EST/CMC, CRL/OCSP, КСЗІ, КЕП та національних криптографічних алгоритмів у цьому документі позначаються окремо як цільові або нормативні вимоги і не трактуються як уже реалізовані функції.

1. Умовні скорочення та визначення

Термін / Скорочення	Значення
IAS	Identity and Authorization Service
CA	Certificate Authority
VPN	Virtual Private Network
PKI	Public Key Infrastructure
CSR	Certificate Signing Request
CMP	Certificate Management Protocol (RFC 4210)
EST	Enrollment over Secure Transport (RFC 7030)
CMC	Certificate Management over CMS (RFC 5272)
BPE	Business Process Engine
BPMN	Business Process Model and Notation
KVS	Key-Value Storage
ABAC	Attribute-Based Access Control
FSM	Finite State Machine
OTP	Open Telecom Platform

2. Статуси вимог і тверджень

Щоб не змішувати фактичну реалізацію, план розвитку та нормативні наміри, у документі використовуються такі статуси:

Статус	Зміст
Реалізовано	Підтверджено поточним кодом і тестами IAS.
Частково реалізовано	Реалізовано частково або лише для конкретного доменного сценарію.
Цільовий стан	Цільова архітектура або функція наступної ітерації.
Нормативна вимога	Нормативна, сертифікаційна або організаційна вимога; не є доказом реалізації.

3. Загальні відомості

3.1. Призначення

IAS централізує керування цифровими ідентичностями, пристроями, сертифікатами, профілями безпеки, VPN-сервісами та зв'язками між ними. IAS є джерелом бажаного стану для керування VPN-конфігурацій і координує підготовку та передавання конфігурацій, але не бере участі у пересиланні VPN-трафіку.

3.2. Поточний функціональний контур

- **Реалізовано:** стійке доменне сховище KVS/Mnesia та версіоновані записи.
- **Реалізовано:** граф користувач–пристрій–сертифікат–профіль безпеки–VPN-сервіс.
- **Реалізовано:** попередній перегляд та імпорт OVPN, перевірка CSR і X.509, ланцюжок походження сертифікатів та оцінювання довіри у межах поточного IAS/VPN домену.
- **Реалізовано:** майстер прив'язаного до пристрою налаштування VPN з перевітками переходів, готовності матеріалів, виправленням помилок та відновленням чернетки.
- **Реалізовано:** IAS → VPN Erlang RPC, канонічні команди, ревізії, контрольна сума, ідемпотентність, журналювання доставки і захист від застарілих ревізій.
- **Реалізовано:** звіряння стану, виявлення осиротілих записів, відновлення або виведення з експлуатації та відновлення після перезапуску.
- **Частково реалізовано:** випуск сертифікатів через CA; поточний CMP-шлях через зовнішній командний інтерфейс OpenSSL є перехідним, а OpenSSL має бути повністю усунений із середовища виконання IAS.
- **Цільовий стан:** керування повним життєвим циклом через synrc/bpmn/BPE.

3.3. Нормативна рамка

Застосовні закони, ДСТУ, ISO/IEC/IEEE, NIST та RFC розглядаються як джерела вимог і критеріїв аудиту. Факт згадки стандарту не означає, що сертифікація, атестація або повна технічна відповідність уже завершені.

4. Архітектурні межі

4.1. IAS і CA

- **Поточний стан / Частково реалізовано:** IAS містить адаптер випуску сертифікатів за CMP, який запускає зовнішній командний інтерфейс OpenSSL і звертається до точки доступу CA для CMP.
- **Цільовий стан:** IAS не запускає OpenSSL або інші зовнішні криптографічні засоби командного рядка. CSR та контекст випуску передаються до CA через керований клієнт або сервісний адаптер; CMP може бути збережений як протокол взаємодії.
- Приватний ключ пристрою не повинен передаватися до IAS або CA.
- EST і CMC не входять до поточної реалізації IAS і можуть розглядатися лише як майбутні адаптери.

4.2. IAS і VPN

- IAS є джерелом бажаного стану керованих VPN-вузлів і сервісів.
- Доставка виконується через розподілений Erlang RPC канонічними командами з ревізією та контрольною сумою.
- VPN застосовує команди і зберігає власний стійкий стан виконання.

- IAS веде журналювання доставки, стан очікування/застосування, виявляє застарілі ревізії та відновлює доставку після перезапуску або повторного з'єднання.
- Звіряння стану порівнює авторитетний стан IAS зі знімком стану VPN і формує інциденти та дії відновлення або виведення з експлуатації.

4.3. Веб-інтерфейс і сховище

- Браузер ↔ IAS: N2O/NITRO/Cowboy.
- Зберігання даних IAS: KVS/Mnesia через доменні модулі сховища.
- `ias_demo_store` використовується як фасад/проекція для інтерфейсу користувача та демо-сценаріїв і не визначає окрему продуктивну БД.

5. Функціональні вимоги

5.1. Доменна модель

IAS повинен підтримувати щонайменше такі класи об'єктів:

- користувач, пристрій, сертифікат, профіль безпеки, політика безпеки, VPN-сервіс;
- випуск і перевірка сертифікатів;
- транзакція підготовки конфігурації, стан доставки та журналювання доставки;
- граф зв'язків між користувачами, пристроями, сертифікатами, профілями та сервісами;
- Інцидент звіряння стану, відновлення або усунення осиротілого запису та бар'єр виведення з експлуатації.

5.2. Життєвий цикл майстра налаштування VPN

Центральний керований процес поточної версії має таку послідовність:

1. Схема.
2. Користувач.
3. Пристрій.
4. Профіль і політика безпеки.
5. VPN-сервіс.
6. Сертифікат СА.
7. Клієнтський сертифікат.
8. Зв'язки.
9. Готовність матеріалів.
10. Підготовка та передавання конфігурації.

Кроки майстра та правила переходу наведено в таблиці ??.

Табл. 3: Кроки майстра налаштування VPN

Крок	Необхідні матеріали	Умова переходу	Результат
Схема	Обрана схема налаштування	Схему вибрано та збережено в чернетці	Зафіксовано варіант подальшого процесу
Користувач	Наявний або створений користувач	Користувача вибрано та його ідентифікатор збережено	Зафіксовано власника пристрою
Пристрій	Наявний або створений пристрій	Пристрій належить вибраному користувачеві	Зафіксовано керований пристрій
Профіль і політика безпеки	Профіль безпеки та пов'язана політика	Профіль доступний для обраного сценарію	Зафіксовано правила перевірки й доступу
VPN-сервіс	Зареєстрований VPN-сервіс	Сервіс доступний і сумісний із профілем	Зафіксовано ціль передавання конфігурації
Сертифікат CA	Довірений сертифікат CA	Матеріал CA чинний і доступний	Зафіксовано ланцюжок довіри
Клієнтський сертифікат	CSR і випущений або імпортований сертифікат	Сертифікат узгоджений із CSR, пристроєм і профілем	Зафіксовано матеріал ідентифікації пристрою
Зв'язки	Користувач, пристрій, сертифікат, профіль і сервіс	Граф зв'язків узгоджений або виправлений	Зафіксовано цілісний доменний граф
Готовність матеріалів	Усі попередні матеріали та зв'язки	Перевірки довіри, авторизації й повноти успішні	Зафіксовано готовність до передавання
Підготовка та передавання конфігурації	Канонічна команда, ревізія і контрольна сума	Транзакцію створено і команда прийнята VPN або поставлена в чергу повтору	Зафіксовано стан «застосовано», «обмежено» або «помилка»

Поточна реалізація повинна забезпечувати:

- стійку чернетку із поточним кроком та вибраними доменними ідентифікаторами;
- умови переходів і заборону руху вперед без необхідних матеріалів;
- автоматичне застосування або ручне виправлення графа зв'язків;
- перевірку матеріалів сертифікатів, стан довіри та рішення про авторизацію;
- створення ідемпотентної транзакції підготовки VPN-конфігурації;
- доставку бажаного стану до VPN і відображення результату «застосовано», «обмежено» або «помилка»;
- повторні спроби, відновлення після перезапуску і звіряння стану після недоступності VPN.

5.3. Імпорт OVPN

Імпорт OVPN є допоміжним процесом первинного підключення. Система повинна аналізувати конфігурацію, визначати вбудовані блоки CA, сертифіката та ключа і параметри підключення, формувати попередній перегляд та створювати погоджені доменні об'єкти без збереження приватного ключа в IAS.

5.4. CSR та сертифікати

- IAS повинен приймати зовнішній CSR, перевіряти формат, власника запиту та криптографічну узгодженість доступними засобами OTP.
- IAS повинен зв'язувати випущений сертифікат із CSR, пристроєм, користувачем і профілем безпеки.
- Перевірка строку чинності, видавця, відбитка, незмінності відкритого ключа та узгодженості зв'язків є обов'язковою.
- Перевірка CRL/OCSP у режимі реального часу належить до **цільового стану**, доки окрема інтеграція не реалізована і не протестована.

5.5. Авторизація і довіра

Поточна реалізація використовує профілі, політики, атрибути доменних об'єктів, граф зв'язків і довіру до сертифікатів для рішень у IAS/VPN сценарії. Це **часткова реалізація ABAC**: універсальна мова опису політик, зовнішні джерела атрибутів, геолокаційні правила та універсальний рушій ABAC належать до **цільового стану**.

5.6. Передавання конфігурацій і звірення стану

- Кожна керована зміна повинна мати канонічне представлення, ревізію і контрольну суму.
- Повторна доставка однакової команди повинна бути ідемпотентною.
- Застарілі ревізії не повинні перезаписувати новіший стан.
- Поточний і застосований стани повинні зберігатися після перезапуску.
- Осиротілий запис, невідповідність відбитка сертифіката, застаріла ревізія та неавторизований стан VPN повинні відображатися як інциденти звірення стану.
- Дії з відновлення та виведення з експлуатації повинні бути аудованими та захищеними від повторного застосування старого бажаного стану.

6. Нефункціональні вимоги

6.1. Архітектура і надійність

- Реалізація на Erlang/OTP із деревами нагляду і безпечними щодо перезапуску переходами станів.
- Авторитетне зберігання даних у KVS/Mnesia.
- Явні версії схем та логіка оновлення і міграції для стійких записів.
- Автоматизовані EUnit і Common Test сценарії для доменних сховищ, підготовки й передавання конфігурацій, RPC, звірення стану та відновлення.
- Кількісні цільові показники SLA, місткості та затримки повинні підтверджуватися окремими навантажувальними та приймальними випробуваннями; до цього вони мають статус **Цільовий стан**.

6.2. Безпека

- Приватні ключі користувачів і пристроїв не зберігаються в IAS.
- Секрети, ключовий матеріал і повні значення облікових даних не записуються в журнали аудиту та системні журнали.
- Захист транспортного рівня, автентифікація вузлів і розподіл секретів повинні бути визначені для кожного профілю розгортання.
- КСЗІ ГЗ, CAAdES-X Long, ДСТУ 4145-2002, ДСТУ ГОСТ 28147:2009 та шифрування даних у сховищі належать до **нормативних вимог або цільового стану**, доки немає окремих реалізаційних і атестаційних доказів.

6.3. Логування і аудит

- IAS повинен аудувати переходи життєвого циклу, випуск та імпорт, рішення про авторизацію, доставку конфігурацій, інциденти звіряння стану та дії відновлення.
- Записи аудиту повинні мати ідентифікатор об'єкта, ревізію, результат, причину та часову мітку.
- Сховище WORM та передавання до ELK/Loki і довгострокове нормативне зберігання є окремими вимогами до розгортання та нормативної відповідності, а не автоматичною властивістю поточної реалізації.

6.4. Документація

- Технічні вимоги, техноробочий проект і політики повинні використовувати однакові статуси «Реалізовано», «Частково реалізовано», «Цільовий стан» і «Нормативна вимога».
- API/OpenAPI, настанови оператора та профілі безпеки створюються відповідно до фактично наявних інтерфейсів.
- BPMN/FSM-діаграми повинні спочатку відображати поточний життєвий цикл; виконання через BPE додається після реалізації відповідної інтеграції із середовищем виконання.

7. Простежуваність вимог

ID	Вимога	Статус	Доказ / зона реалізації
IAS-FR-001	Стійкий реєстр користувачів, пристроїв, сертифікатів, профілів і VPN-сервісів	Реалізовано	доменні модулі сховища, тести KVS/Mnesia
IAS-FR-002	Перевірка CSR і X.509	Реалізовано	модулі сертифікатів і налаштування, тести
IAS-FR-003	Випуск сертифікатів через CA без зовнішнього командного інтерфейсу OpenSSL у середовищі виконання IAS	Цільовий стан	керований клієнт або адаптер CA
IAS-FR-004	Майстер прив'язаного до пристрою налаштування VPN	Реалізовано	майстер, готовність матеріалів, зв'язки, авторизація

IAS-FR-005	Доставка IAS → VPN через RPC	Реалізовано	модулі клієнта VPN і доставки, набори СТ
IAS-FR-006	Ревізія, контрольна сума, ідентичність і захист від застарілих даних	Реалізовано	стан доставки та підготовки конфігурацій, тести
IAS-FR-007	Звіряння стану, відновлення осиротілих записів і виведення з експлуатації	Реалізовано	модулі звіряння й відновлення, набори СТ
IAS-FR-008	Керування процесами через BPE/BPMN	Цільовий стан	заплановане перенесення керування майстром
IAS-FR-009	Адаптери CRL/OCSP, EST і CMC	Цільовий стан	відсутні у поточному середовищі виконання
IAS-NFR-001	КСЗІ ГЗ, КЕП, криптографія за ДСТУ, шифрування даних у сховищі	Нормативна вимога	потребує окремої реалізації та підтвердних матеріалів

8. Додаток А. Межі поточної версії

Поточна версія не повинна описуватися як така, що вже забезпечує повну універсальну ABAC-платформу, EST/CMC, перевірку CRL/OCSP у режимі реального часу, загальний набір інтерфейсів REST/OpenAPI, TLS 1.3 для всіх каналів, зберігання даних у RocksDB/NVMe, аудит у сховищі WORM, гарантовані 100000 пристроїв, 50 мс затримку, КСЗІ ГЗ, CAdES-X Long або реалізацію національної криптографії. Такі твердження можуть бути включені лише як «Цільовий стан» або «Нормативна вимога» з окремими критеріями приймання.

9. Додаток Б. Цільова послідовність розвитку

Послідовність робіт задається пріоритетами та залежностями, наведеними нижче. Наступний етап не повинен вважатися завершеним, доки не виконано його критерій результату.

Пріоритет	Робота	Залежить від	Очікуваний результат
P0	Синхронізувати <code>ias.tex</code> і <code>ias_pro.tex</code> з поточним кодом	Немає	Документи коректно розмежовують реалізовані, частково реалізовані, цільові та нормативні вимоги
P1	Повністю усунути запуск зовнішнього командного інтерфейсу OpenSSL із середовища виконання IAS, зберігши CMP або інший погоджений контракт через керований клієнт або адаптер CA	P0	Випуск сертифікатів не залежить від локального виконаного файлу OpenSSL у IAS

P2	Прогнати і стабілізувати повний життєвий цикл майстра налаштування VPN	P1	Наскрізний сценарій від користувача і пристрою до передавання конфігурації відтворюється, перевіряється тестами та відновлюється після збоїв
P3	Зафіксувати поточну FSM/BPMN-модель реального життєвого циклу	P2	Стани, переходи, умови, помилки, повторні спроби та завершення описані без розбіжностей із кодом
P4	Поетапно перенести керування процесом на <code>syncs/bpmn/BPE</code> , зберігаючи доменні сервісні модулі, перевірену поведінку та майстер як користувацький інтерфейс процесу	P3	BPE є джерелом стану й керує переходами, а майстер залишається інтерфейсом над процесом: відображає його стан і надсилає команди
P5	Повторно синхронізувати технічні вимоги, техноробочий проєкт і профілі безпеки	P4	Документація, реалізація, випробування і профілі безпеки описують один погоджений стан системи

Інвентаризація мережевих портів та сервісів у профілях безпеки виконується паралельно як окремий неблокувальний напрям, але її результати мають бути враховані не пізніше етапу P5.